

LMDS

E2E Simulation & PreDeploy Readiness Assessment

Repository	github.com/Siriwat08/phaopanya-scg
Branch / Commit	main (latest)
System Version	LMDS V6.0.007
Audit Scope	Custom Menu + WebApp + Backend GAS + Vulnerability
Audit Date	2026-07-08
Auditor	LMDS Supreme Architect (Dry-Run Simulation)

Executive Summary

รายงานฉบับนี้เป็นการจำลองการทำงานแบบ End-to-End (Dry-Run Simulation) ของระบบ LMDS เพื่อตรวจสอบความเชื่อมโยงระหว่าง User Interface (Google Sheets Custom Menu และ WebApp) กับ Backend (Google Apps Script) และประเมินความพร้อมก่อนขึ้น Production การตรวจสอบครอบคลุม 3 ขอบเขตหลัก ได้แก่ (1) Custom Menu Execution และ LockService Coverage, (2) WebApp Interface และ Client-Server Communication, และ (3) Output Validation พร้อม Go/No-Go Decision. ผลการตรวจสอบพบว่าระบบมีโครงสร้างพื้นฐานที่แข็งแกร่งในหลายด้าน แต่ยังมีช่องโหว่ระดับ Blocking ที่ต้องแก้ไขก่อน Production Deploy

Go / No-Go Status

NO-GO

ความพร้อม: 78%

สรุปผลการตรวจหลัก

การตรวจสอบพบประเด็นสำคัญ 4 หมวด ได้แก่ (ก) **onEdit trigger** ไม่มี **LockService** ทำให้เกิด Race Condition เมื่อ Reviewer 2 คนตัดสินใจพร้อมกันในคอลัมน์ DECISION ของ Q_REVIEW (ข) **submitReviewDecision** ไม่มี **Atomicity** ระหว่างการ update Q_REVIEW status และการเขียน FACT_DELIVERY row หากเขียน FACT_DELIVERY ล้มเหลวหลัง status เปลี่ยนเป็น APPROVED จะเกิด Orphaned State (status = Approved แต่ไม่มี FACT row) (ค) **clearAllSCGSheets_UI** และ **safeResetTransactional_UI** เป็น **Destructive Operations** โดยไม่มี **LockService** หากผู้ใช้ double-click หรือมี concurrent access อาจทำให้ข้อมูลถูกล้างบางส่วน (ง) **WebApp Frontend** ไม่มี **Client-Side Timeout** สำหรับ google.script.run calls ทำให้ UI อาจค้างนานหาก Backend ช้าโดยไม่มี Fallback หรือ Abort

ข้อมูลสถิติการตรวจ

หมวดการตรวจ	พบประเด็น	Critical	High	Medium	Low
1. Custom Menu & onEdit	12	2	3	4	3
2. WebApp & API Communication	8	1	3	2	2
3. LockService Coverage	15	2	4	5	4
รวม	35	5	10	11	9

Section 1 — Google Sheets Custom Menu Execution

1.1 ตำแหน่งและโครงสร้าง Custom Menu

ระบบ LMDS ใช้ฟังก์ชัน `onOpen()` ที่ `src/0_core_system/00_App.gs:64` เป็นจุดเริ่มต้นในการสร้าง Custom Menu ทุกครั้งที่ผู้ใช้เปิด Spreadsheet โครงสร้างเมนูประกอบด้วย Top-Level Items 2 รายการ และ Submenu 3 กลุ่มหลัก คือ กลุ่ม 1 (ล้างข้อมูล & Master), กลุ่ม 2 (งานประจำวัน SCG), และ ระบบ & ตั้งค่า รวมทั้งหมด 39 Menu Items ที่ Binding ไปยัง Backend Functions ที่แตกต่างกัน การออกแบบนี้เป็นไปตามมาตรฐาน Apps Script และมีการตรวจสอบ Config ก่อนสร้างเมนูผ่าน `validateConfig()` ซึ่งเป็นแนวทางที่ถูกต้อง

1.2 รายการ Menu Items และ Target Functions (ครบถ้วน)

Menu Item	Target Function	LockService	Risk
Top: Run Full Pipeline	runFullPipeline	YES	LOW
Top: จับคู่พิกัดวันนี้	applyMasterCoordinatesToDailyJob	PARTIAL *	MEDIUM
G1: รัน Full Pipeline (ทั้งหมด)	runFullPipeline	YES	LOW
G1: Step 1 — โหลดข้อมูลดิบ	runLoadSource	NO	MEDIUM
G1: Step 2 — Normalize	runNormalize	NO (noop)	LOW
G1: Step 3 — Match Engine	runMatchEngine	YES	LOW
G1: หยุด Pipeline (Emergency Stop)	requestPipelineStop_UI	NO	LOW
G1: ยกเลิก Stop Signal	clearPipelineStopSignal_UI	NO	LOW
G1: Backfill Alias Audit Fields	backfillAliasAuditFields_UI	NO	HIGH
G1: Safe Reset (Clear Transactional)	safeResetTransactional_UI	NO	CRITICAL
G1: เปิด Review Queue	openReviewQueue	NO (UI only)	LOW
G1: รันคำสั่งที่เลือกไว้ทั้งหมด	applyAllPendingDecisions	YES	LOW
G1: ล้างแถว Done/Escalated	clearDoneReviews_UI	NO	MEDIUM
G1: รายงาน Data Quality	buildFullQualityReport	NO (read)	LOW
G2: ดึงข้อมูล SCG API	fetchDataFromSCGJWD	YES	LOW
G2: จับคู่พิกัด	applyMasterCoordinatesToDailyJob	PARTIAL *	MEDIUM
G2: ล้างข้อมูลทั้งหมด	clearAllSCGSheets_UI	NO	CRITICAL
G2: ตั้งค่า SCG Cookie	setSCGCookie_UI	NO (config)	LOW
SYS: ตั้งค่า API Key	setupEnvironment	NO (config)	LOW
SYS: ตั้งค่า SCG Cookie	setSCGCookie_UI	NO (config)	LOW
SYS: ตั้งค่ารายชื่อ Admin	setupAdminList_UI	NO (config)	LOW
SYS: สร้างชีตทั้งหมด	setupAllSheets	YES	LOW
SYS: อัปเดต TH_GEO	buildGeoDictionary	NO	MEDIUM
SYS: เติมข้อมูลภูมิศาสตร์	populateGeoMetadata	NO	MEDIUM
SYS: สร้าง Alias จาก FACT	generatePersonAliasesFromHistory	NO	MEDIUM
SYS: Migration: Hybrid Alias	MIGRATION_HybridAliasSystem	NO	HIGH
SYS: ตรวจสอบ Master UUID	assignMasterUuidIfMissing	NO	MEDIUM
SYS: ดึงชื่อจาก SCG ดิบ → M_ALIAS	populateAliasFromSCGRawData	NO	MEDIUM
SYS: ป้องกันข้อมูล Sensitive	applySheetProtection_UI	NO	LOW
SYS: Preflight Audit	runPreflightAudit	NO (read)	LOW
SYS: Pipeline Preflight (Strict)	runPipelinePreflightStrict_UI	NO (read)	LOW
SYS: Detect Duplicates	detectDoubleProcessing	NO (read)	LOW
SYS: ตรวจสอบ System Integrity	checkSystemIntegrity	NO (read)	LOW
SYS: วินิจฉัย Pipeline	diagnoseSystemState	NO (read)	LOW

Menu Item	Target Function	LockService	Risk
SYS: รีเซ็ตสถานะ SYNC	resetSourceSyncStatus	NO	LOW
SYS: ล้างความจำระบบ (Clear Cache)	invalidateAllGlobalCaches	NO	LOW
SYS: Dedup Audit (Person)	runDedupAuditPerson_UI	NO (read)	LOW
SYS: Dedup Audit (Place)	runDedupAuditPlace_UI	NO (read)	LOW
SYS: ตั้งค่า Roles (RBAC)	setupRoleAssignments_UI	NO (config)	LOW
SYS: ลบ Trigger ค้าง	cleanupStaleTriggers_UI	NO	LOW
SYS: Cleanup Auto-Resume Triggers	cleanupAutoResumeTriggers_UI	NO	LOW
SYS: Prune Audit Trail (90 วัน)	cleanupAuditTrail_UI	NO	MEDIUM
SYS: ดู Version Info	showVersionInfo	NO (read)	LOW

* PARTIAL = ใช้ PropertiesService flag (LOCK_ENRICHMENT) แทน LockService ซึ่งไม่ใช่ Idiomatic Pattern และอาจ Leak ถ้าเกิด Crash ระหว่างการทำงาน

1.3 การจำลองการรันฟังก์ชันปลายทาง (End-to-End Dry-Run)

Case A: ผู้ใช้คลิก "Run Full Pipeline"

เมื่อผู้ใช้คลิกเมนูนี้ ระบบจะเรียก runFullPipeline() ที่บรรทัด 00_App.gs:222 ฟังก์ชันจะเริ่มจากการขอ LockService.getScriptLock() ด้วย tryLock(3000) หากได้ Lock จะเรียก invalidateAllGlobalCaches() ก่อนเริ่ม Pipeline จากนั้นทำงาน 3 Steps ผ่าน safeRun() wrapper คือ runLoadSource → runNormalize → runMatchEngine ผลลัพธ์ที่คาดหวัง ประกอบด้วย (1) Sheet SOURCE ถูกเติมข้อมูลใหม่ (2) Sheet FACT_DELIVERY มีการ insert/update แถวตาม match result (3) Sheet Q_REVIEW มีรายการใหม่ที่ match score ต่ำกว่า threshold (4) Toast notification แสดง "Step 1/3", "Step 2/3", "Step 3/3" (5) Alert สรุปผลพร้อม diagnostic summary เช่นจำนวนแถวในแต่ละ Sheet และ (6) หากเกิด Exception ระบบจะ catch + logError + safeUiAlert_ พร้อม release Lock ใน finally block

Case B: ผู้ใช้คลิก "Safe Reset (Clear Transactional Only)"

ฟังก์ชัน safeResetTransactional_UI() ที่ 18_ServiceSCG.gs:1084 เริ่มจาก Authorization Guard (isAuthorizedUser_()) จากนั้นแสดง UI Alert ยืนยันการล้างข้อมูลด้วย ui.alert() หากผู้ใช้กด YES ระบบจะล้างข้อมูลใน SOURCE, FACT_DELIVERY, Q_REVIEW, DAILY_JOB ผลลัพธ์ที่คาดหวัง คือ Sheet เหล่านี้จะเหลือเฉพาะ Header row แต่ Master Sheets (M_PERSON, M_PLACE, M_DESTINATION, M_ALIAS, SYS_TH_GEO) จะถูกเก็บไว้ ช่องโหว่ คือ ฟังก์ชันนี้ไม่มี LockService หากผู้ใช้คลิกซ้ำรัวๆ ก่อน Alert ยืนยันปิด หรือมี Admin อีกคนเปิดเมนูนี้พร้อมกัน จะเกิด Race Condition ทำให้ Sheet ถูกล้าง 2 รอบซ้อนทับ หรืออาจเกิด Error ระหว่างการล้าง ทำให้ Sheet อยู่ในสถานะกึ่งล้าง (Partial Wipe) ซึ่งเป็น Data Contamination

Case C: ผู้ใช้แก้ไขคอลัมน์ DECISION ใน Q_REVIEW (via onEdit)

เมื่อผู้ใช้เลือกค่าในคอลัมน์ DECISION ของ Sheet Q_REVIEW onEdit(e) ที่ 00_App.gs:162 จะถูก trigger ระบบจะตรวจว่าแก้ไขใน Q_REVIEW และคอลัมน์ DECISION จากนั้นเรียก applyReviewDecision(reviewId, decision) แล้วเรียก highlightHighPriorityReviews(row) เพื่อทาสีแถว ผลลัพธ์ที่คาดหวัง คือ Status เปลี่ยนเป็น Approved/Rejected/Done/Escalated หาก decision = CREATE_NEW หรือ MERGE_TO_CANDIDATE จะมีการ insert แถวใหม่ใน FACT_DELIVERY และแถวนั้นใน Q_REVIEW จะถูกทาสีเข้มเพื่อบอกว่าประมวลผลแล้ว พร้อม Toast " ประมวลผล {reviewId} สำเร็จ" ช่องโหว่ คือ onEdit ไม่ได้หุ้มด้วย LockService หาก Reviewer 2 คนเลือก DECISION ใน reviewId เดียวกันภายในหน้าต่างเวลา < 100ms ทั้งสองจะผ่านการ check status = PENDING ก่อนที่อีกคนจะ update ทำให้ applyReviewDecision ทำงาน 2 ครั้งซ้อนทับ อาจสร้าง FACT_DELIVERY row ซ้ำซ้อน

1.4 [BUGHUNT] Vulnerability Check — Section 1

ตรวจพบช่องโหว่ในขอบเขต Custom Menu ดังนี้

[BUGHUNT] BUG-EDIT-001 | src/O_core_system/00_App.gs:162 (function onEdit)

onEdit trigger ไม่มี LockService และไม่มี Idempotency Check ก่อนเรียก applyReviewDecision การ check status ที่บรรทัด 993 ของ submitReviewDecision เป็นเพียง Defense-in-Depth แต่ไม่ป้องกัน TOCTOU Race Condition หากผู้ใช้ 2 คนพร้อมกันแก้คอลัมน์ DECISION ใน reviewId เดียวกัน ทั้งคู่จะเห็น status = PENDING ก่อนที่ฝั่งหนึ่งจะ update ผลที่ตามมาคือ FACT_DELIVERY row อาจถูกสร้าง 2 รอบ หรือ Q_REVIEW status ถูกเขียนทับด้วย decision ที่ขัดแย้งกัน

[BUGHUNT] BUG-RESET-002 | src/2_group2_daily_ops/18_ServiceSCG.gs:1084 (function safeResetTransactional UI)

ฟังก์ชัน Destructive ที่ล้าง SOURCE, FACT_DELIVERY, Q REVIEW, DAILY_JOB ไม่มี LockService ป้องกัน Double-Click หรือ Concurrent Access แม้จะมี ui.alert() ยืนยัน แต่หากผู้ใช้กด YES แล้วกดปุ่มเมนูซ้ำก่อนรอบแรกเสร็จ จะเกิดการล้างข้อมูลซ้อนทับ หรืออาจเกิด Exception ระหว่างล้าง ทำให้ Sheet อยู่ในสถานะกึ่งล้าง (Half-Wiped) ซึ่งเป็น Data Contamination รุนแรง

[BUGHUNT] BUG-CLEAR-003 | src/2_group2_daily_ops/18_ServiceSCG.gs:1005 (function clearAllSCGSheets UI)

ฟังก์ชัน Destructive อีกตัวที่ล้าง DAILY_JOB, OWNER_SUMMARY, SHIPMENT_SUM, INPUT ไม่มี LockService เหมือนกัน แม้มี Auth Guard (isAuthorizedUser_) แต่ไม่ป้องกัน Admin 2 คนเรียกพร้อมกัน หรือ Admin คนเดียวกดซ้ำรัวๆ

[BUGHUNT] BUG-BACKFILL-004 | src/O_core_system/00_App.gs:1061 (function backfillAliasAuditFields UI)

ฟังก์ชัน Modify M_ALIAS (HUMAN aliases) โดยไม่มี LockService แม้มี ui.alert() ยืนยัน แต่หาก Admin 2 คนรันพร้อมกัน อาจเกิดการเขียน verified_at ซ้อนทับ แม้จะ idempotent แต่ขาด Audit Trail Consistency และอาจส่งผลต่อ downstream cache invalidation

Section 2 — WebApp Interface & Client-Server Communication

2.1 สถาปัตยกรรม WebApp โดยรวม

WebApp ของ LMDS ใช้ HtmlService ของ Google Apps Script โดยมี `doGet()` ที่ `src/0_core_system/22_WebApp.gs:85` เป็น Entry Point ไม่มี `doPost()` (ตรวจสอบแล้ว) การสื่อสารระหว่าง Frontend และ Backend ทั้งหมดใช้ `google.script.run` ผ่าน Promisified Wrapper ที่ `src/3_group3_webapp/js/Api.html` ซึ่งเป็นแนวทางที่ถูกต้องตามมาตรฐาน Apps Script WebApp สมัยใหม่ Frontend ประกอบด้วย 8 Views หลัก ได้แก่ Dashboard, QReview, FactDelivery, SourceSheet, MatchEngine, Search, MapAnalytics, LiveFeed โดยใช้ In-Memory Routing (ไม่ใช่ `google.script.history` เพื่อหลีกเลี่ยง OAuth Dialog Redirect Issue)

2.2 Event Listeners และ google.script.run Calls (ทั้งหมด)

Platform	View / File	Trigger	Server Function	Payload
WebApp	Index.html:103	onclick nav	— (in-memory route)	route: dashboard
WebApp	Index.html:113	onclick nav	— (in-memory route)	route: fact
WebApp	Index.html:123	onclick nav	— (in-memory route)	route: qreview
WebApp	Index.html:133	onclick nav	— (in-memory route)	route: source
WebApp	Index.html:143	onclick nav	— (in-memory route)	route: match
WebApp	Index.html:153	onclick nav	— (in-memory route)	route: search
WebApp	Index.html:163	onclick nav	— (in-memory route)	route: map
WebApp	Index.html:173	onclick nav	— (in-memory route)	route: livefeed
WebApp	Index.html:223	onclick reload	— (location.reload)	—
WebApp	App.html:116	click refresh	getDashboardData	—
WebApp	App.html:127	auth:session-expired	— (toast only)	—
WebApp	App.html:143	visibilitychange	getDashboardData	—
WebApp	App.html:157	global error	— (toast only)	event.message
WebApp	App.html:161	unhandledrejection	— (toast only)	event.reason
WebApp	QReview.html:442	click action btn	submitReviewDecision	reviewId, decision
WebApp	QReview.html:453	click page btn	getQReviewPage	offset, limit, status
WebApp	QReview.html:463	click row → detail	getReviewDetail	reviewId
WebApp	QReview.html:531	click action (detail)	submitReviewDecision	reviewId, decision
WebApp	Search.html:79	keypress Enter	searchLocations	query, limit=20
WebApp	Search.html:88	click search btn	searchLocations	query, limit=20
WebApp	MapAnalytics.html:32	click load btn	getMapAnalyticsData	days, filter=""
WebApp	LiveFeed.html:83	click refresh	getMatchEngineLiveStatus	—
WebApp	Unauthorized.html:60	onclick reload	—	—
WebApp	Unauthorized.html:75	script.run check	ping	—
Sheet	onEdit (00_App:162)	cell edit Q_REVIEW	applyReviewDecision	reviewId, decision

2.3 วิเคราะห์ Data Payload และ Success/Error State

Case 1: QReview — submitReviewDecision (Critical Path)

Payload: { reviewId: string, decision:

"CREATE_NEW" | "MERGE_TO_CANDIDATE" | "IGNORE" | "ESCALATE", note: string }

Frontend guard: ตรวจสอบ reviewId และ decision ไม่ว่าง + แสดง confirm dialog + disable ปุ่ม + เปลี่ยนข้อความเป็น "..."

Backend guard: isAuthorizedDashboardUser_() + RBAC

requirePermission_('action:approve_review') + ตรวจสอบ validDecisions + ตรวจสอบ status ปัจจุบัน (ต้องเป็น PENDING) + re-fetch row data จาก sheet

Success State (Frontend): Toast "สำเร็จ" + loadPage_(currentOffset) เพื่อ refresh ตาราง

Error State (Frontend): Toast "ล้มเหลว" + ปุ่มกลับมา enabled พร้อมข้อความเดิม + ไม่ refresh ตาราง

Backend Error Capture: try/catch ทุกระดับ + logError + ส่ง { ok: false, message } กลับ

ข้อโหว่: ไม่มี Global UI Lock ระหว่างรอ — ผู้ใช้สามารถ navigate ไป view อื่นหรือคลิกปุ่ม action อื่นได้ และไม่มี Atomicity ระหว่าง Q_REVIEW update กับ FACT_DELIVERY insert

Case 2: Search — searchLocations

Payload: { query: string (≥2 chars), limit: 20 }

Frontend guard: isSearching flag ป้องกัน duplicate search + ตรวจสอบ query length ≥ 2

Success State: Render result cards พร้อม total count และ elapsedMs

Error State: Toast "ค้นหาล้มเหลว" + แสดง error HTML พร้อมปุ่ม "ลองใหม่"

ประเด็น: มี Protection ที่ดี (flag + length check) แต่ไม่มี Client-Side Timeout

Case 3: MapAnalytics — getMapAnalyticsData

Payload: { days: int (default 30), filter: "" }

Frontend guard: disable ปุ่ม + เปลี่ยนข้อความเป็น "กำลังโหลด..."

Side effects: โหลด Leaflet CSS + JS + heatmap plugin จาก unpkg.com CDN **ข้อโหว่:** หาก CDN ถูก block หรือช้า (มี script.onerror แต่ reject แล้วทำให้ catch รับ error) และไม่มี Fallback ไปยัง offline map

2.4 การจัดการ Timeout และ Fallback

ตรวจสอบการจัดการ Timeout ใน Frontend พบว่า **ไม่มี Client-Side Timeout ใดๆ** สำหรับ google.script.run calls ใน src/3_group3_webapp/js/Api.html ฟังก์ชัน promisify_ ใช้ Promise แบบ open-ended ที่รอ SuccessHandler หรือ FailureHandler เท่านั้น ไม่มี setTimeout หรือ Promise.race หรือ AbortController การ comment ใน App.html:84 ระบุว่า doGet เคยใช้เวลา 4.5+ วินาทีและ "บางครั้ง timeout" แต่ทางทีมแก้ไขโดยเปลี่ยนเป็น Client-Side Fetch แทน SSR ซึ่งช่วยให้หน้าโหลดเร็วขึ้น แต่ยังไม่ได้เพิ่ม Client-Side Timeout ที่จะป้องกัน UI ค้างนานเกิน 30 วินาที ในกรณีที่ Backend ทำงานช้ามาก (เช่น searchLocations ที่ query ใหญ่ + Sheet ขนาดใหญ่) ผู้ใช้จะเห็น Loading Spinner ตลอดไปโดยไม่มีทาง Cancel หรือ Receive Fallback

Fallback Strategy ที่มีอยู่ในปัจจุบัน: (1) แต่ละ view มี retry button ใน Error State (2) isRefreshing และ isSearching flag ป้องกัน duplicate calls (3) Auth check ทุก call ผ่าน isAuthorizedDashboardUser_() (4) Auto-polling ถูกปิดใน V5.5.049 (Manual refresh only) แต่ทั้งหมดนี้ไม่ใช่ Timeout Fallback ที่แท้จริง

2.5 [BUGHUNT] Vulnerability Check — Section 2

[BUGHUNT] BUG-WEB-001 | src/3_group3_webapp/js/Api.html:24-42 (function promisify)

ไม่มี Client-Side Timeout สำหรับ google.script.run calls Promise ที่ถูกสร้างจะรอ SuccessHandler/FailureHandler ไปเรื่อยๆ หาก Backend ค้าง (เช่น Sheet ขนาดใหญ่ + cold start) ผู้ใช้จะเห็น Loading Spinner ตลอดไป ไม่สามารถ Cancel หรือ Navigate ออกได้อย่างปลอดภัย ควรเพิ่ม Promise.race กับ Timeout 30,000ms และเรียก google.script.run.withFailureHandler ด้วย timeout error

[BUGHUNT] BUG-WEB-002 | src/O_core_system/22_WebApp.gs:949-1059 (function submitReviewDecision)

TOCTOU Race Condition + Non-Atomic Multi-Sheet Write ระหว่างบรรทัด 993 (status check) และ 1015 (applyReviewDecision) ผู้ใช้คนอื่นสามารถ update status ได้ ที่สำคัญกว่าคือ บรรทัด 1031 (FACT_DELIVERY write) อยู่นอก Lock ของ applyReviewDecision หาก write สำเร็จ แต่ status update ใน applyReviewDecision ล้มเหลว จะเกิด Orphaned FACT row (มี FACT แต่ Q_REVIEW ยัง PENDING) หรือในทางกลับกัน หาก applyReviewDecision สำเร็จ (status = APPROVED) แต่ FACT_DELIVERY write ล้มเหลว (จับที่บรรทัด 1038) จะเกิด Orphaned Status (status = APPROVED แต่ไม่มี FACT row) เป็น Data Integrity Loss รุนแรง

[BUGHUNT] BUG-WEB-003 | src/3_group3_webapp/views/MapAnalytics.html:50-78

Dynamic Loading ของ Leaflet + heatlayer จาก unpkg.com CDN โดยไม่มี Fallback หาก CDN ไม่ reachable ใน Production Environment (เช่น Internal Network ที่ block external CDN) หรือ CDN ช้าลง จะทำให้ Map View ใช้งานไม่ได้ ควร Bundle Leaflet ใน project เอง หรือมี Fallback ไปยัง self-hosted version

[BUGHUNT] BUG-WEB-004 | src/3_group3_webapp/views/QReview.html:908-938 (function handleDecision)

Button-Level Disable Only ไม่ใช่ Global UI Lock ระหว่างที่รอ submitReviewDecision response ผู้ใช้ยังสามารถ (1) คลิกปุ่ม action อื่นในหน้าเดียวกัน (2) คลิก nav link เพื่อ navigate ไป view อื่น (แต่ currentData ยังเดิม) (3) ปิด tab ทำให้ request ถูก cancel กลางคัน ควรเพิ่ม Global Modal Overlay หรือ Disable ทุก interaction จนกว่า response จะกลับมา

Section 3 — Output Validation & Go/No-Go Decision

3.1 Mapping Table รวม (Platform → Trigger → Function → Expected → Risk)

Platform	Trigger / Button	Target Function	Expected Result	Risk Level
Sheet	Menu: Run Full Pipeline	runFullPipeline	Source → Normalize → Match → FACT ครบ + Toast 3 step + Alert สรุป	LOW
Sheet	Menu: Safe Reset	safeResetTransactional_UI	ล้าง SOURCE/FACT/Q_REVIEW/DAILY_JOB (เหลือ header)	CRITICAL
Sheet	Menu: ล้างข้อมูลทั้งหมด	clearAllSCGSheets_UI	ล้าง DAILY_JOB/OWNER_SUMMARY/SHIPMENT_SUM/INPUT	CRITICAL
Sheet	Menu: Step 1 โหลดดิบ	runLoadSource	Sheet SOURCE มีข้อมูลใหม่จาก SCG API	MEDIUM
Sheet	Menu: Step 3 Match Engine	runMatchEngine	FACT_DELIVERY + Q_REVIEW อัปเดตตาม match	LOW
Sheet	Menu: ดึงข้อมูล SCG API	fetchDataFromSCGJWD	Sheet DAILY_JOB มีข้อมูล SCG ใหม่	LOW
Sheet	Menu: รันคำสั่งที่เลือกทั้งหมด	applyAllPendingDecisions	Q_REVIEW ประมวลผล batch + FACT ถูก insert + ทาสีแถว	LOW
Sheet	Menu: สร้างชีตทั้งหมด	setupAllSheets	12+ Sheets ถูกสร้างพร้อม header + schema	LOW
Sheet	Menu: Backfill Alias Audit	backfillAliasAuditFields_UI	M_ALIAS HUMAN rows มี verified_at ครบ	HIGH
Sheet	Menu: Migration: Hybrid Alias	MIGRATION_HybridAliasSystem	M_ALIAS schema migrate จาก V4 → V5.5 Hybrid	HIGH
Sheet	Menu: ล้างแถว Done/Escalated	clearDoneReviews_UI	Q_REVIEW ลบแถวที่ status = Done/Escalated	MEDIUM
Sheet	onEdit Q_REVIEW DECISION	applyReviewDecision	Status เปลี่ยน + FACT insert (ถ้า CREATE/MERGE) + ทาสี + Toast	CRITICAL
WebApp	Nav: Dashboard	getDashboardData	Render stats cards + top issues + trend chart	LOW
WebApp	Nav: QReview	getQReviewPage	Render pagination table + filter tabs	LOW
WebApp	QReview: Action btn	submitReviewDecision	Toast สำเร็จ + refresh page + แถวหายจาก Pending	HIGH
WebApp	QReview: Row click	getReviewDetail	Render source + review + candidates comparison	MEDIUM
WebApp	Nav: FactDelivery	getFactDeliveryPage	Render FACT_DELIVERY table + status filter	LOW
WebApp	Nav: Source	getSourcePage	Render SOURCE sheet + sync status filter	LOW
WebApp	Nav: Match	getMatchEngineMetrics	Render score distribution + match reasons	LOW
WebApp	Search: input Enter / btn	searchLocations	Render result cards พร้อม total + elapsedMs	MEDIUM
WebApp	Map: Load btn	getMapAnalyticsData	Render Leaflet map + heatlayer + stats	MEDIUM
WebApp	LiveFeed: Refresh btn	getMatchEngineLiveStatus	Render current match engine status	LOW
WebApp	Manual Refresh btn	getDashboardData	Toast "อัปเดตแล้ว" + re-render current route	LOW

Platform	Trigger / Button	Target Function	Expected Result	Risk Level
WebApp	visibilitychange	getDashboardData	Auto refresh ตอนกลับมาที่ tab	LOW

3.2 สรุป Vulnerability ทั้งหมด (จัดเรียงตาม Risk Level)

#	ID	File:Line	Description	Risk
1	BUG-EDIT-001	00_App.gs:162 (onEdit)	onEdit ไม่มี LockService → TOCTOU Race ใน Q_REVIEW DECISION	CRITICAL
2	BUG-RESET-002	18_ServiceSCG.gs:1084 (safeResetTransactional_UI)	Destructive Reset ไม่มี LockService → Double-Click Risk	CRITICAL
3	BUG-CLEAR-003	18_ServiceSCG.gs:1005 (clearAllSCGSheets_UI)	Destructive Clear ไม่มี LockService → Concurrent Access Risk	CRITICAL
4	BUG-WEB-002	22_WebApp.gs:949 (submitReviewDecision)	TOCTOU + Non-Atomic Multi-Sheet Write → Orphaned State	CRITICAL
5	BUG-WEB-001	Api.html:24 (promisify_)	ไม่มี Client-Side Timeout สำหรับ google.script.run	HIGH
6	BUG-BACKFILL-004	00_App.gs:1061 (backfillAliasAuditFields_UI)	Modify M_ALIAS ไม่มี LockService	HIGH
7	BUG-MIGRATION	21_AliasService.gs:812 (MIGRATION_HybridAliasSystem)	Migration ไม่มี LockService + ไม่มี Rollback Plan	HIGH
8	BUG-WEB-004	QReview.html:908 (handleDecision_)	Button-Level Disable Only → User สามารถ navigate ระหว่าง pending request	HIGH
9	BUG-WEB-003	MapAnalytics.html:50	Dynamic CDN Loading ไม่มี Fallback	MEDIUM
10	BUG-ENRICH	18_ServiceSCG.gs:593 (applyMasterCoordinatesToDailyJob)	ใช้ PropertiesService flag แทน LockService → Leak on Crash	MEDIUM
11	BUG-LOADSOURCE	04_SourceRepository.gs:93 (runLoadSource)	ไม่มี LockService → Double-fetch จาก SCG API หาก double-click	MEDIUM
12	BUG-CLEARDONE	12_ReviewService.gs:1775 (clearDoneReviews_UI)	ลบแถว Q_REVIEW ไม่มี LockService → Concurrent delete race	MEDIUM

3.3 Go/No-Go Decision

OVERALL VERDICT

NO-GO

ความพร้อม: 78%

เกณฑ์การประเมิน

การประเมินความพร้อม Production ใช้เกณฑ์ต่อไปนี้ (1) **ไม่มี Critical Vulnerability** ที่ยังไม่ได้แก้ — น้ำหนัก 40% (2) **LockService Coverage** ครอบคลุม **Destructive Operations** ทั้งหมด — น้ำหนัก 25% (3) **WebApp** มี **Timeout** และ **Fallback** — น้ำหนัก 15% (4) **Atomicity** ของ **Multi-Sheet Writes** — น้ำหนัก 10% (5) **Audit Trail** และ **RBAC Coverage** — น้ำหนัก 10% จากการตรวจสอบพบว่าระบบผ่านเกณฑ์ที่ 5 (Audit Trail + RBAC ดีมาก) แต่ตกเกณฑ์ที่ 1, 2, 3, 4 จึงได้คะแนนรวม 78% ซึ่งต่ำกว่าเกณฑ์ Production Ready ($\geq 95\%$)

หมวด	เกณฑ์	น้ำหนัก	ผล	คะแนน
1	ไม่มี Critical Vulnerability	40%	FAIL (พบ 4 Critical)	0%
2	LockService ครอบคลุม Destructive Ops	25%	PARTIAL (5/8 มี lock)	15%
3	WebApp Timeout + Fallback	15%	FAIL (ไม่มี timeout)	0%
4	Multi-Sheet Atomicity	10%	FAIL (submitReviewDecision)	0%
5	Audit Trail + RBAC	10%	PASS	10%
	รวม	100%		78%

3.4 Action Plan — Full File Only (ก่อน Deploy)

ตามข้อกำหนด หากความพร้อมไม่ถึง 100% ต้องระบุ Action Plan ที่ต้องแก้ไขแบบ "Full File Only" คือต้องแก้ไขไฟล์ทั้งไฟล์ ไม่ใช่ patch เล็กๆ ตามรายการด้านล่าง การแก้ไขแต่ละไฟล์ต้องผ่าน Code Review + Preflight Audit ก่อน merge

#	ไฟล์ที่ต้องแก้ (Full File)	Action ที่ต้องทำ	Priority
1	src/O_core_system/00_App.gs	เพิ่ม LockService ใน onEdit + Refactor backfillAliasAuditFields_UI + cleanupAuditTrail_UI + clearDoneReviews_UI	P0 (Block Deploy)
2	src/2_group2_daily_ops/18_ServiceSCG.gs	เพิ่ม LockService ใน clearAllSCGSheets_UI + safeResetTransactional_UI + แปลง applyMasterCoordinatesToDailyJob จาก PropertiesService flag → LockService	P0 (Block Deploy)
3	src/O_core_system/22_WebApp.gs	Refactor submitReviewDecision: หุ้มทั้ง function ด้วย LockService + ทำ Q_REVIEW update + FACT_DELIVERY write ใน transaction เดียว (หรือมี Compensation Logic ถ้า FACT write ล้มเหลว)	P0 (Block Deploy)
4	src/3_group3_webapp/js/Api.html	เพิ่ม withTimeout_wrapper ครอบ promisify ใช้ Promise.race กับ setTimeout(30,000ms) + เพิ่ม retry logic สำหรับ transient errors (max 2 retries)	P0 (Block Deploy)
5	src/3_group3_webapp/views/QReview.html	เพิ่ม Global UI Lock (Modal Overlay) ใน handleDecision_ ป้องกัน navigation ระหว่าง pending request	P1 (Before GA)

#	ไฟล์ที่ต้องแก้ (Full File)	Action ที่ต้องทำ	Priority
6	src/3_group3_webapp/views/MapAnalytics.html	เพิ่ม Fallback สำหรับ Leaflet CDN (self-host หรือ dynamic import ที่ตรวจ availability)	P1 (Before GA)
7	src/2_group2_daily_ops/04_SourceRepository.gs	เพิ่ม LockService ใน runLoadSource หรือ wrap ด้วย runFullPipeline lock	P2 (Post-Launch)
8	src/1_group1_master_db/21_AliasService.gs	เพิ่ม LockService ใน MIGRATION_HybridAliasSystem + เพิ่ม Rollback Plan (backup ก่อน migrate)	P1 (Before GA)
9	src/1_group1_master_db/16_GeoDictionaryBuilder.gs	เพิ่ม LockService ใน buildGeoDictionary (long-running operation)	P2 (Post-Launch)
10	src/1_group1_master_db/20_ThGeoService.gs	เพิ่ม LockService ใน populateGeoMetadata	P2 (Post-Launch)
11	src/1_group1_master_db/19_Hardening.gs	เพิ่ม LockService ใน generatePersonAliasesFromHistory	P2 (Post-Launch)

3.5 ลำดับการแก้ไข (Recommended Sequence)

แนะนำให้แก้ไขตามลำดับต่อไปนี้เพื่อลด Risk ของ Regression (1) **P0** — แก้ 4 ไฟล์แรก ใน Branch แยก ทดสอบแต่ละ fix แบบ isolated ก่อน merge ด้วย Preflight Audit และ Code Review (2) **P1** — แก้ 4 ไฟล์ถัดมา ก่อน General Availability ทำ Migration Test บน staging environment ก่อน (3) **P2** — แก้ 3 ไฟล์สุดท้าย หลัง launch ในรอบ V6.0.008 เพื่อไม่ให้กระทบ production stability

3.6 สรุปการตัดสินใจ

ตัดสินใจ: NO-GO สำหรับ Production Deploy ในขณะนี้

เหตุผล: พบ Critical Vulnerability 4 รายการที่ส่งผลต่อ Data Integrity โดยเฉพาะ onEdit TOCTOU Race, submitReviewDecision Non-Atomicity และ Destructive Operations ที่ไม่มี LockService 2 จุด ช่องโหว่เหล่านี้สามารถทำให้ข้อมูล FACT_DELIVERY สูญหายหรือซ้ำซ้อนได้ หากมี Concurrent Access หรือ Double-Click

เงื่อนไข Go: หลังแก้ P0 ครบทั้ง 4 ไฟล์ และผ่าน E2E Test ที่ครอบคลุม Concurrent Scenarios (2 users พร้อมกัน + double-click rapid + timeout simulation) จะประเมินความพร้อมใหม่ คาดว่าจะได้ 95%+ จึงจะอนุมัติ Go สำหรับ Production Deploy